

Lecture 23 : System Hacking

Introduction

In the realm of cybersecurity, understanding and exploiting vulnerabilities in software is a critical skill for both defenders and attackers. This session delves into the practical aspects of identifying and leveraging weaknesses in application software to gain unauthorized access to a target system, specifically focusing on a Windows environment. We will explore a step-by-step methodology, starting from initial reconnaissance and vulnerability scanning, progressing through the use of advanced exploitation frameworks like Metasploit, and culminating in privilege escalation to achieve full control over the compromised machine. This hands-on approach demonstrates how a seemingly minor application flaw can open the door to significant security breaches, highlighting the importance of robust patch management and secure coding practices.

The journey begins with identifying open services on a target machine and then pinpointing specific application versions known to harbor vulnerabilities. Once a vulnerable application is found, specialized tools are employed to craft and deliver an exploit, establishing an initial foothold. However, initial access often comes with limited privileges, necessitating further steps to escalate permissions to an administrative level. This process of privilege escalation is crucial for performing actions like dumping password hashes, which can then be used for further lateral movement or persistent access. By understanding these techniques, students can better grasp the attacker's mindset and develop more effective defensive strategies against real-world threats.

Core Concepts

Term	Definition	Significance
nmap	A powerful open-source network scanner used to discover hosts and services on a computer network by sending packets and analyzing their responses.	Essential for initial reconnaissance, identifying open ports and the services running on them, which is the first step in finding potential vulnerabilities.
Metasploit Framework	A penetration testing platform that provides a comprehensive collection of exploits,	The primary tool used in this demonstration for exploiting identified vulnerabilities and

Term	Definition	Significance
	payloads, and auxiliary modules for security professionals.	managing post-exploitation activities, streamlining the hacking process.
BadBlue httpd 2.7	A specific version of a lightweight HTTP server application, identified as having known vulnerabilities.	Serves as the target application in this lecture, demonstrating how a specific, outdated, or poorly coded application can be the entry point for system compromise.
meterpreter	An advanced, dynamic, and extensible payload that provides an interactive shell to the attacker, allowing for extensive post-exploitation control over the compromised system.	The primary interface for interacting with the target system after successful exploitation, offering a wide range of commands for information gathering, privilege escalation, and more.
hashdump	A meterpreter command used to extract password hashes from the Security Account Manager (SAM) database on a Windows system.	Crucial for obtaining credentials that can be used for offline cracking, lateral movement within a network, or maintaining persistence on the target system.
Privilege Escalation	The act of exploiting a bug, design flaw, or configuration oversight in an operating system or application to gain elevated access to resources that are normally protected from an application or user.	A necessary step when initial access provides limited user privileges, allowing an attacker to gain administrative or system-level control over the target machine.
migrate	A meterpreter command used to move the meterpreter session from	Enhances the stability and stealth of the meterpreter session by moving it into a more legitimate and stable

Term	Definition	Significance
	one process to another on the target system.	process, making it harder to detect and terminate.
bypassuac	A category of exploits designed to bypass Windows User Account Control (UAC) mechanisms, which are intended to prevent unauthorized changes to the operating system.	A key technique for privilege escalation on Windows systems, allowing an attacker to elevate their privileges from a standard user to an administrator or system user.
getsystem	A meterpreter command specifically designed to attempt to elevate the current session's privileges to SYSTEM (the highest privilege level on Windows).	The ultimate goal of privilege escalation, granting full control over the operating system and its resources, enabling actions like hashdump .

Detailed Analysis

1. Initial Reconnaissance and Vulnerability Identification

The first phase of any penetration test or hacking attempt involves gathering information about the target system. This typically begins with network scanning to identify active hosts, open ports, and the services running on them.

- **Port Scanning with **nmap**** : The **nmap** tool is used to perform a quick scan of common ports to identify potential entry points.

```
nmap -T4 -P 1-1000 10.35.1.199
```

- **-T4** : Specifies an aggressive timing template, which speeds up the scan.
- **-P 1-1000** : Scans ports from 1 to 1000.
- **10.35.1.199** : The target IP address.
- The scan reveals several open TCP ports, including 80 (HTTP), 135, 139, and 445.

- **Service Version Scanning with nmap** : To identify specific application versions, a more detailed service scan is performed. This is crucial because vulnerabilities are often tied to particular software versions.

```
nmap -T4 -sV 10.35.1.199
```

- `-sV` : Enables service version detection.
- The service scan results indicate that port 80 is running `BadBlue httpd 2.7` . This specific version is known to be vulnerable, making it an ideal target for exploitation. The `BadBlue httpd` service is commonly used for file transfer.

2. Exploiting Application Vulnerability with Metasploit

Once a vulnerable service and its version are identified, the next step is to find and deploy an appropriate exploit using a framework like Metasploit.

- **Launching Metasploit and Searching for Exploits:** The Metasploit Framework is started, and a search is conducted for exploits related to the `badblue` service.

```
msfconsole  
search badblue
```

- The search yields two relevant exploits: `exploit/windows/http/badblue_ext_overflow` (disclosure 2003) and `exploit/windows/http/badblue_passthru` (disclosure 2007).
- The `badblue_passthru` exploit is chosen because its description explicitly states it targets `BadBlue version 2.7` , matching the identified vulnerable service.
- **Configuring and Executing the Exploit:** The selected exploit needs to be configured with the target's details before execution.

```
use exploit/windows/http/badblue_passthru  
show options
```

- The `show options` command displays the parameters that need to be set, primarily `RHOST` (remote host IP address).

```
set RHOST 10.35.1.199
```

- `RPORT` (remote port) is already correctly set to 80, as the `BadBlue` service runs on this port.
- With the options configured, the exploit is launched.

```
exploit
```

- Successful execution results in a `meterpreter` session being opened, indicating that the target system has been compromised. The `meterpreter` session provides an interactive shell for post-exploitation activities.

3. Post-Exploitation: Initial Access and Limitations

Upon gaining the initial `meterpreter` session, it's important to gather basic information about the compromised system and understand the current privilege level.

- **System Information Gathering:** The `sysinfo` command provides details about the target operating system.

```
sysinfo
```

- The output confirms the target is running Windows 7.
- **Attempting `hashdump` and Privilege Check:** A common goal after initial compromise is to extract password hashes. The `hashdump` command is used for this purpose.

```
hashdump
```

- However, `hashdump` fails, indicating insufficient privileges.
- To confirm the current user's privilege level, the `getuid` command can be used (though not explicitly shown in the transcript for this initial check, it's implied by the `hashdump` failure). The transcript mentions the username `WIN\U07C2K\exploiter`, confirming it's not an administrative account. This highlights the need for privilege escalation.

4. Process Migration for Stability

Before attempting privilege escalation, it's often a good practice to migrate the `meterpreter` session to a more stable and legitimate process. This makes the session more resilient to detection and termination.

- **Listing Processes:** The `ps` command lists all running processes on the target system, along with their Process IDs (PIDs) and Parent Process IDs (PPIDs).

```
ps
```

- This command provides a list of processes, from which a suitable target for migration can be chosen.
- **Migrating the Session:** The `meterpreter` session is migrated to a stable process, such as `iexplore.exe` (Internet Explorer), using its PID.

```
migrate 2176
```

- `2176` : The Process ID of the `iexplore.exe` process.
- The migration is reported as successful, ensuring the `meterpreter` session is now running within a more benign and less suspicious process.
- **Backgrounding the Session:** To free up the current console for further Metasploit operations (like privilege escalation), the `meterpreter` session is sent to the background.

```
background
```

- This allows the attacker to interact with the Metasploit console while the `meterpreter` session continues to run in the background. The session is assigned a session ID (e.g., session 2).

5. Privilege Escalation Techniques

With the initial `meterpreter` session running in the background, the next critical step is to escalate privileges to an administrative or system level.

- **Searching for Privilege Escalation Exploits:** Metasploit is used to search for exploits specifically designed for privilege escalation, often targeting User Account Control (UAC) bypasses on Windows.

```
search bypassuac
```

- This search reveals various `bypassuac` exploits available within Metasploit.
- **Configuring and Executing a `bypassuac` Exploit:** One of the `bypassuac` exploits is selected and configured.

```
use exploit/windows/local/bypassuac_injection  
show options
```

- The `show options` command reveals that the exploit requires a `SESSION` ID, which refers to the existing `meterpreter` session.

```
set SESSION 2
```

- The `SESSION` is set to 2, corresponding to the backgrounded `meterpreter` session.

```
exploit
```

- Executing the exploit attempts to bypass UAC and open a new `meterpreter` session with elevated privileges. A new `meterpreter` session (e.g., session 3) is opened.
- **Verifying Privilege Escalation:** After the `bypassuac` exploit, the privilege level of the new session is checked.

```
getuid
```

- Initially, the `getuid` command might still show a non-administrative user, indicating that the `bypassuac` exploit might have only elevated to an administrator token but not full `SYSTEM` privileges.
- **Achieving `SYSTEM` Privileges with `getsystem`:** To gain the highest level of privilege (`SYSTEM`), the `getsystem` command is used within the `meterpreter` session.

```
getsystem
```

- This command attempts various techniques to elevate the session to `SYSTEM`. If successful, it reports "got system via technique 1 in memory admin."
- **Final Privilege Verification:** The `getuid` command is used again to confirm the successful privilege escalation.

```
getuid
```

- This time, the output confirms that the session now has `NT AUTHORITY\SYSTEM` privileges, signifying full administrative control over the target machine.

6. Dumping Hashes with Elevated Privileges

With `SYSTEM` privileges, the `hashdump` command can now be successfully executed to extract password hashes.

- **Executing `hashdump` :**

```
hashdump
```

- The command successfully retrieves the hash values of user passwords from the target machine's SAM database. These hashes can then be used for offline cracking to obtain plaintext passwords or for "pass-the-hash" attacks.

This entire process demonstrates a complete cycle of exploiting an application vulnerability, gaining initial access, migrating for stability, escalating privileges, and finally extracting sensitive information from a Windows system.

Key Takeaways

- [] Initial reconnaissance using `nmap` is crucial for identifying open ports and services on a target system.
- [] Service version scanning (`nmap -sV`) helps pinpoint specific application versions that may have known vulnerabilities.
- [] Metasploit Framework is a powerful tool for searching, configuring, and executing exploits against identified vulnerabilities.
- [] An initial `meterpreter` session often provides limited user privileges, necessitating further steps for full system control.

- [] Process migration (`migrate`) enhances the stability and stealth of a `meterpreter` session by moving it to a legitimate process.
- [] Privilege escalation techniques, such as `bypassuac` exploits and the `getsystem` command, are essential for gaining administrative or `SYSTEM` level access on Windows.
- [] The `hashdump` command can only successfully extract password hashes from the SAM database when the `meterpreter` session has `SYSTEM` privileges.
- [] Understanding the attacker's methodology, from scanning to privilege escalation, is vital for developing effective defensive strategies.

Conclusion

This session provided a comprehensive walkthrough of exploiting an application software vulnerability to gain control over a Windows machine. We began with the fundamental steps of network scanning using `nmap` to identify open services and their specific versions. The discovery of `BadBlue httpd 2.7`, a known vulnerable application, served as our entry point. Leveraging the Metasploit Framework, we successfully exploited this vulnerability to establish an initial `meterpreter` session. The journey didn't end there; recognizing the limitations of initial user-level access, we demonstrated critical post-exploitation techniques, including migrating the `meterpreter` session to a more stable process and, most importantly, escalating privileges to `SYSTEM` level using `bypassuac` exploits and the `getsystem` command. The ultimate success was marked by the ability to perform a `hashdump`, extracting sensitive password hashes from the compromised system.

The practical demonstration underscores that even seemingly minor application vulnerabilities can lead to full system compromise if not properly addressed. For students and professionals, this knowledge is invaluable, not just for offensive security but also for building robust defensive postures. Understanding how attackers move from initial access to privilege escalation and data exfiltration is key to implementing effective security controls, patch management, and user privilege management. Looking ahead, the principles of exploiting system weaknesses extend beyond technical vulnerabilities, as the next session will explore Social Engineering Attacks, highlighting the human element in the chain of security.